



TLS Client Certificate and Smart Card Logon

Ing. Ondřej Ševeček | GOPAS a.s. |

MCSM:Directory2012 | MCM:Directory2008 | MVP:Enterprise Security | CEH:
Certified Ethical Hacker | CHFI: Computer Hacking Forensic Investigator |
CISA |

ondrej@sevecek.com | www.sevecek.com |

GOPAS: info@gopas.cz | www.gopas.cz | www.facebook.com/P.S.GOPAS

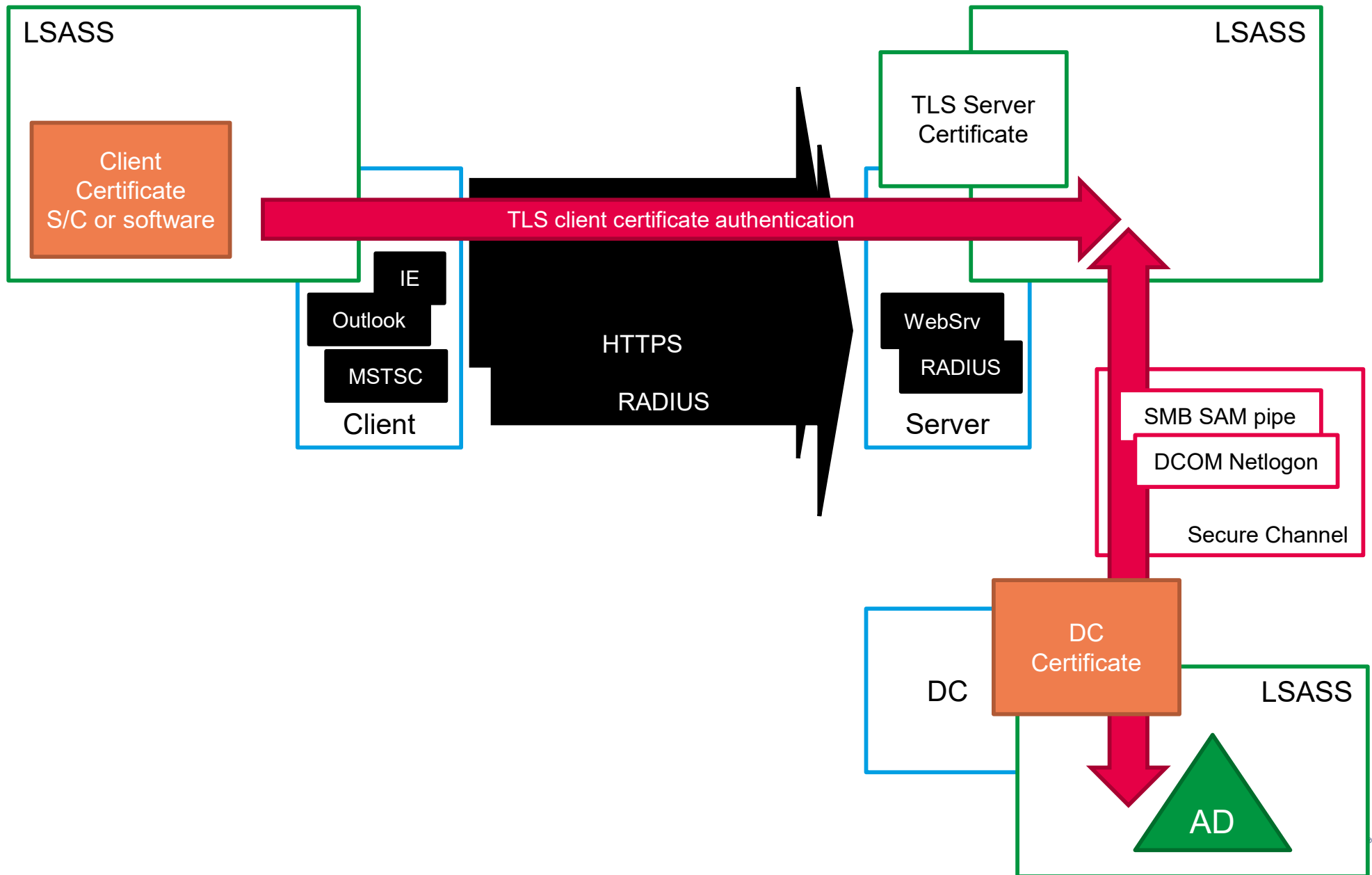
Motivation

- Limit use of **plaintext passwords**
 - hardware keyloggers
 - password sharing
 - remote access
 - long time access
- Work towards **Kerberos**
 - AES encryption
 - more secure delegation
 - Kerberos tickets **faster expiration** (down to 1 hour)
- Limit NTLM and pass-the-XXX attacks
 - **nothing else** can help you absolutely than **best practices**
 - or LSASS credentials in **Virtual Server Protection (VSP)** in Windows 10

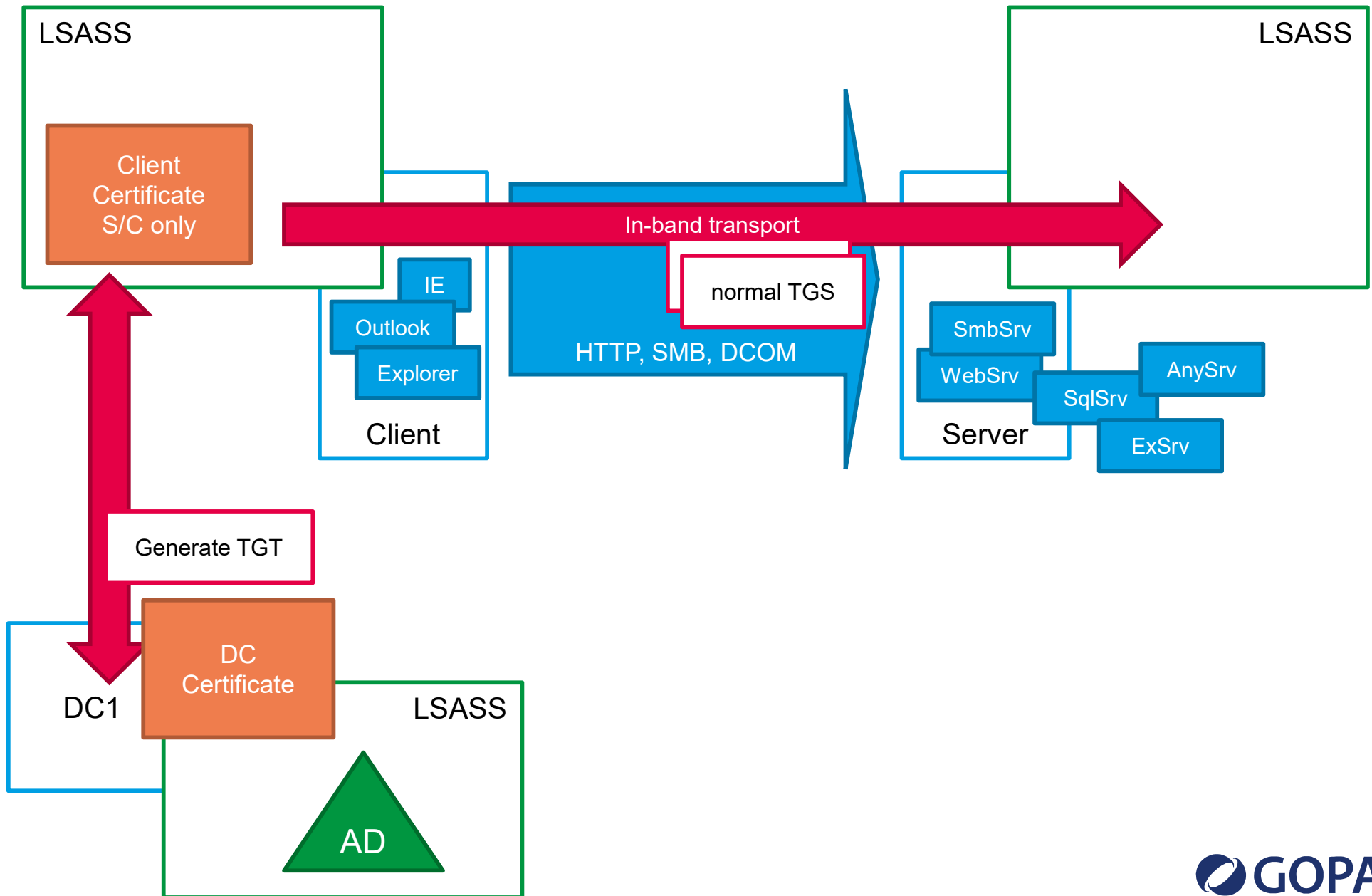
Two certificate authentications

- Interactive **Kerberos PKINIT** logon
 - produce Kerberos TGT with certificate private key pre-authentication
- TLS client certificate authentication (**SChannel**)
 - HTTPS, LDAPS, RADIUS EAP/PEAP
 - web, SSTP, RD Gateway, ADFS, WAP, VPN, WiFi, ...

SChannel TLS client certificate authentication



Kerberos PKINIT



Technical requirements

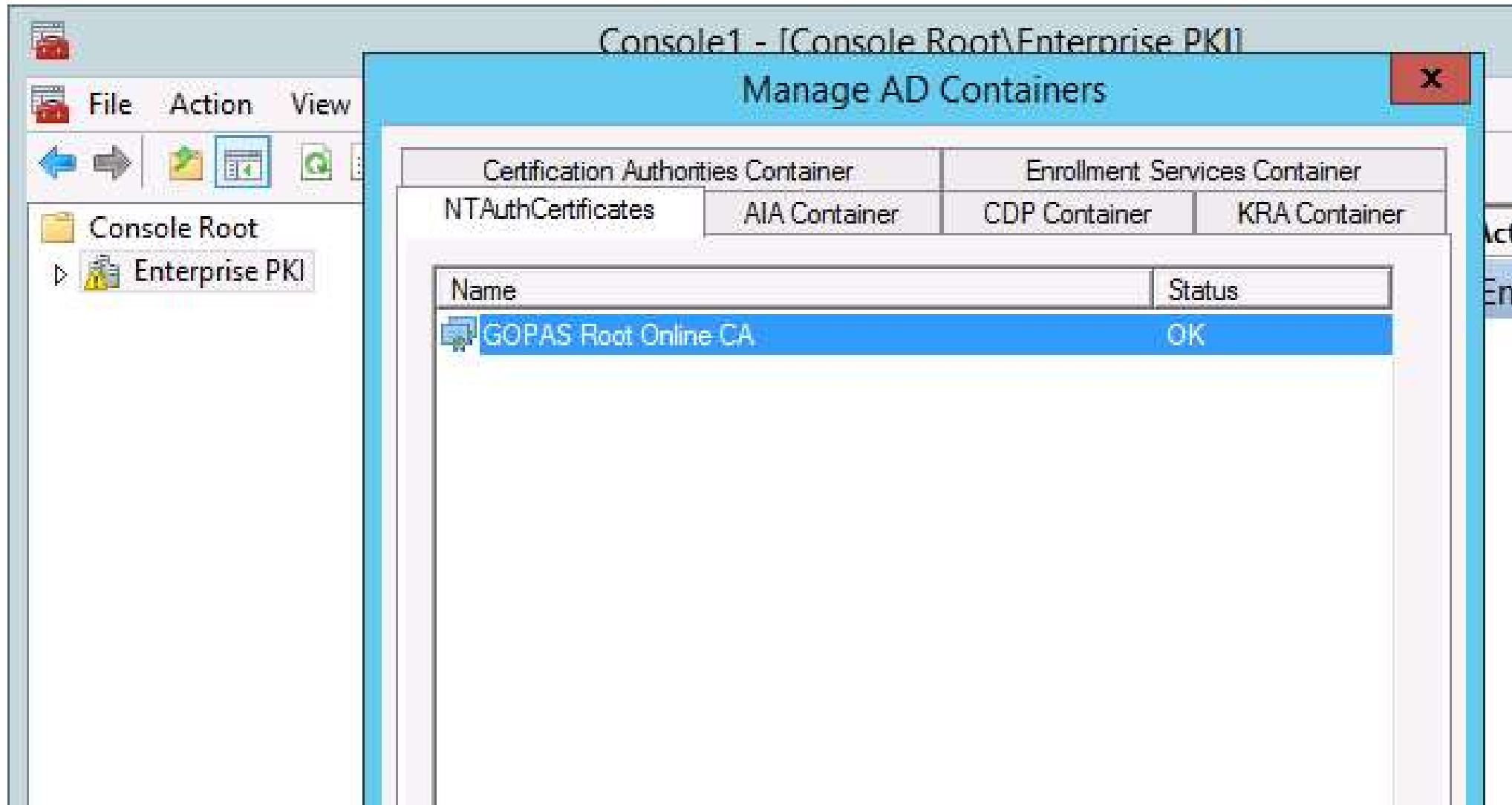
- PKI
- CAs
- DC certificates
- user logon certificates

CA requirements

- Trusted root CA
- NTAAuth trusted **issuing** CA
 - enterprise (AD integrated) ADCS CAs by default
 - **CN=NTAuthCertificates**,CN=Public Key Services,CN=Services,CN=Configuration,DC=x
 - **HKLM**\Software\Microsoft\EnterpriseCertificates**NTAuth**\Certificates
 - ◆ #thumbprint#

```
certutil -enterprise -addstore ntauth issuingCA.cer
```
- CRL valid (OCSP)
 - up-to-date, available, ideally anonymous HTTP

Verify NTAUTH CAs for a forest using Enterprise PKI console



NTAuthCertificates object (CN=Public Key Services,CN=Services,CN=Configuration)

The screenshot displays the ADSI Edit window with the 'CN=NTAuthCertificates Properties' dialog box open. The dialog box has two tabs: 'Attribute Editor' and 'Security'. The 'Attribute Editor' tab is active, showing a list of attributes and their values. The 'cACertificate' attribute is selected, showing its value as '\\30\82\03\A3\30\82\02\88\A0\03\02\01\'. The 'cn' attribute shows the value 'NTAuthCertificates'.

ADSI Edit

File Action View Help

Configuration [GPS-DC1-2012.gopas.vi]

- Configuration [GPS-DC1-2012.gopas.vi]
 - CN=Configuration,DC=gopas,DC=...
 - CN=DisplaySpecifiers
 - CN=Extended-Rights
 - CN=ForestUpdates
 - CN=LostAndFoundConfig
 - CN=NTDS Quotas
 - CN=Partitions
 - CN=Physical Locations
 - CN=Services
 - CN=AuthN Policy Configur...
 - CN=Claims Configuration
 - CN=Group Key Distribution
 - CN=Microsoft SPP
 - CN=MsmqServices
 - CN=NetServices
 - CN=Public Key Services
 - CN=RRAS
 - CN=Sevecek VM Buildup
 - CN=Windows NT
 - CN=Sites
 - CN=WellKnown Security Princip...

Name

- CN=AIA
- CN=CDP
- CN=Certificate Template...
- CN=Certification Authori...
- CN=Enrollment Services
- CN=KRA
- CN=OID
- CN=NTAuthCertificates

CN=NTAuthCertificates Properties

Attribute Editor Security

Attributes:

Attribute	Value
adminDescription	<not set>
adminDisplayName	<not set>
authorityRevocationList	
cACertificate	\\30\82\03\A3\30\82\02\88\A0\03\02\01\
cACertificateDN	<not set>
cAConnect	<not set>
cAUsages	<not set>
cAWEBSITEURL	<not set>
certificateRevocation...	
certificateTemplates	<not set>
cn	NTAuthCertificates
cRLObjct	<not set>
crossCertificatePair	<not set>
currentParentCA	<not set>

Edit Filter

OK Cancel Apply Help

DC certificate requirements (2003+)

- EKU (default template Kerberos Authentication)
 - Server Authentication
 - Client Authentication
 - Smart Card Logon
 - Kerberos Authentication
- SAN
 - DNS domain name
 - NetBIOS domain name
- CRL valid (or OCSP)
 - up-to-date, available, ideally anonymous HTTP
 - from client's perspective
 - `certutil -urlfetch -verify`
 - `certutil -url`

Client certificate requirements

- Stored in smart card in case of Kerberos PKINIT
 - EKU = Smart Card Logon
- Stored in S/C or software provider in case of TLS client certificate logon
 - EKU = Client Authentication
- SAN
 - user principal name (UPN) or dNSHostName
 - manually mapped SAN or subject
- CRL valid (or OCSP)
 - up-to-date, available, ideally anonymous HTTP
 - from DC's perspective
 - `certutil -urlfetch -verify`
 - `certutil -url`

Client certificate SAN vs. Published Certificates on domain user account

Kamil Properties

Published Certificates	Member Of	Password Replication
Security	Environment	Sessions
Remote Desktop Services Profile	COM+	UNIX Attribute
General	Address	Account
Profile	Telephone	

User logon name:

kamil @gopas.cz

User logon name (pre-Windows 2000):

GPS\ kamil

Logon Hours... Log On To...

Kamil Properties ?

Security	Environment	Sessions	Remote control
Remote Desktop Services Profile	COM+	UNIX Attributes	Attribute Editor
General	Address	Account	Profile
Telephones	Organization		
Published Certificates	Member Of	Password Replication	Dial-in
Object			

List of X509 certificates published for the user account

Issued To	Issued By	Intended Purposes	Expiration
-----------	-----------	-------------------	------------

Certificate

General Details Certification Path

Show: <All>

Field	Value
Certificate Template Inform...	Template=1.3.6.1.4.1.25005...
Authority Information Access	[1]Authority Info Access: Acc...
Subject Key Identifier	5d 39 76 71 f8 77 5c e5 a6 68 ...
Subject Alternative Name	Other Name:Principal Name=k...
CRL Distribution Points	[1]CRL Distribution Point: Distr...
Authority Key Identifier	KeyID=15 a3 32 f9 e6 c8 a3 b...
Enhanced Key Usage	Client Authentication (1.3.6.1....
Key Usage	Digital Signature (80)

Other Name:
Principal Name=kamil@gopas.cz

Since May 2023 a SID extension 1.3.6.1.4.1.311.25.2 enforced in logon certificates by the DCs

- find the account by UPN login
- verify SID to match

or

- c) strong-map certificates to user accounts (altSecurityIdentities)

	Jitka S.	User
	Julie S.	User
	Kamil R.	
	Klara K.	
	Leos S.	
	Marie S.	
	Martin N.	
	Pavla N.	

Copy...

Add to a group...

Name Mappings...

Disable Account

Reset Password...

Attributes:

Attribute	Value
accountExpires	(never)
altSecurityIdentities	X509: <I>C=CZ,S=Cz
badPasswordTime	24.09.2024 11:54:46
badPwdCount	0

Field Value

Application Policies	[1]Application Certificate Polic...
Certificate Template Inform...	Template=1.3.6.1.4.1.25005...
1.3.6.1.4.1.311.25.2	30 40 a0 3e 06 0a 2b 06 01 04...
Authority Information Access	[1]Authority Info Access: Acc...
Subject Key Identifier	9c515079f1768e11b69942e5e...
Subject Alternative Name	Other Name:Principal Name=r...
CRL Distribution Points	[1]CRL Distribution Point: Distr...
Authority Key Identifier	KeyID=119a59827b0c86edh3

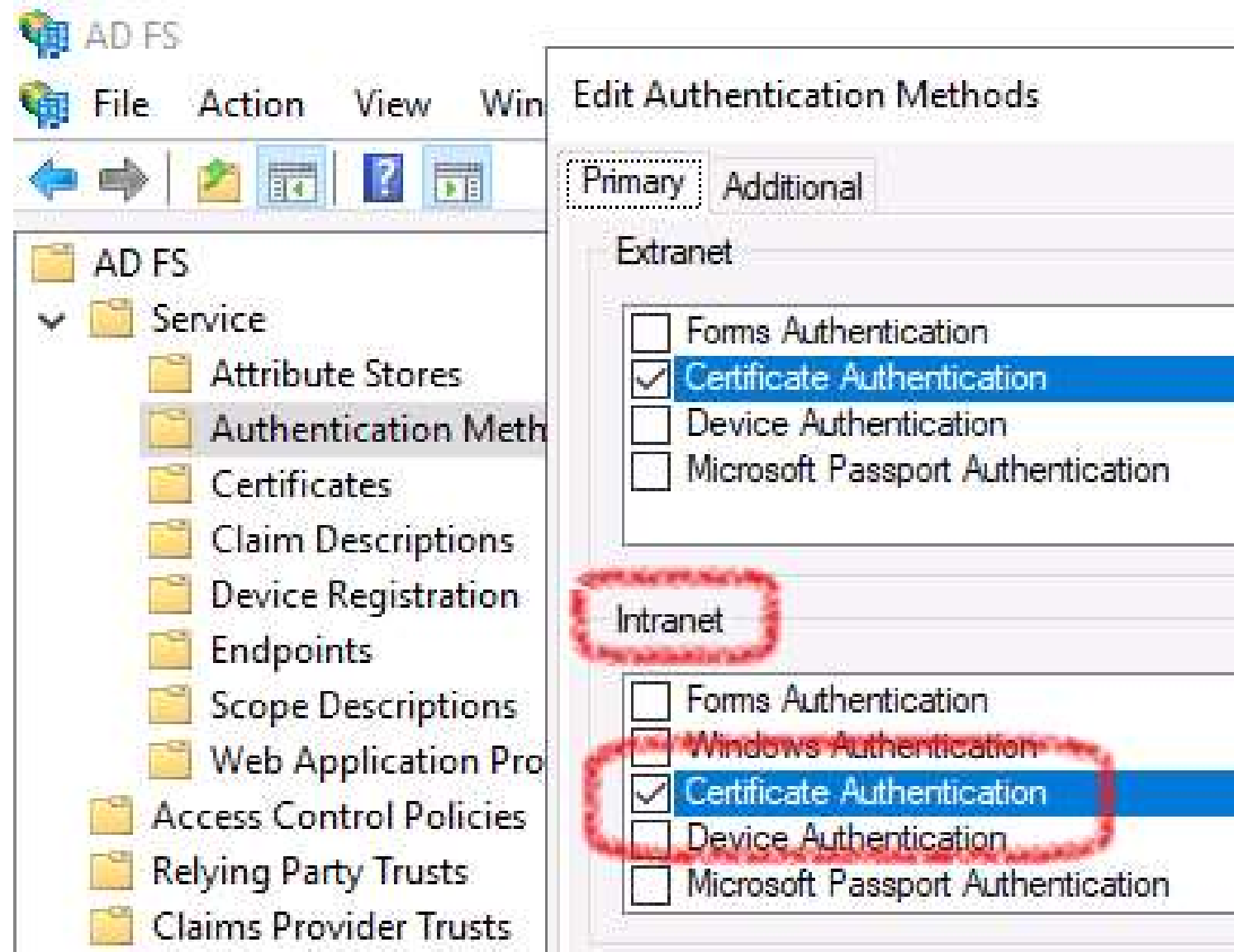
30 40 a0 3e 06 0a 2b 06 01 04 01 82 37 19 02 01 a0 30 04 2e 53 2d 31 2d 35 2d 32 31 2d 32 33 31 37 30 31 39 30 30 36 2d 31 35 33 38 36 35 32 31 39 39 2d 31 31 36 35 34 35 32 31 34 30 2d 31 31

0@.>..+.7... .0..S-1- 5-21-231 7019006- 15386521 99-11654 52140-11

Edit Properties... Copy to File...

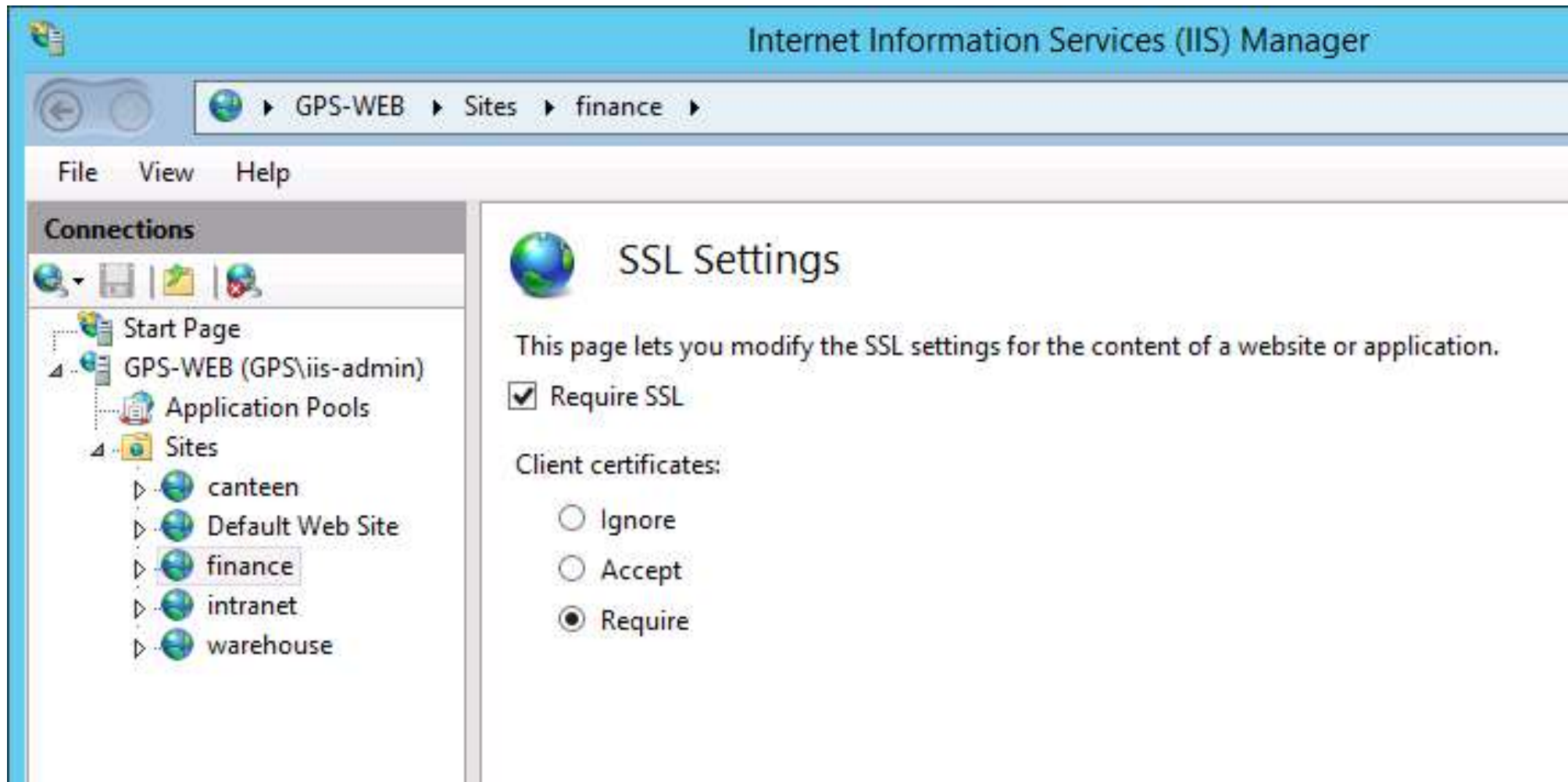
ADFS certificate authentication

<https://adfs.gopas.cz/adfs/LS/IdpInitiatedSignOn>



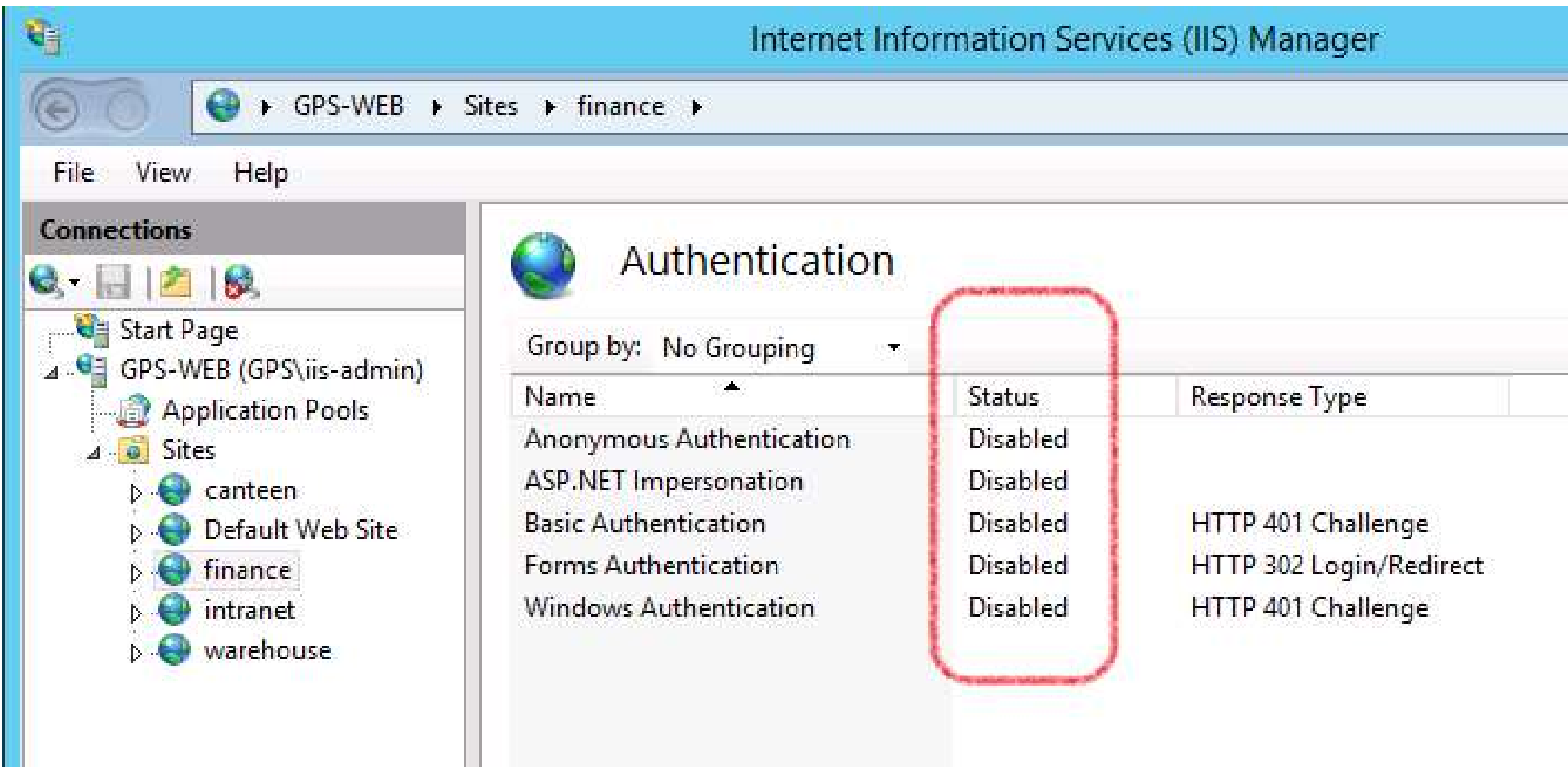
IIS TLS client certificate authentication #1

Enforce TLS and require client certificates



IIS TLS client certificate authentication #2

Disable all HTTP authentication methods



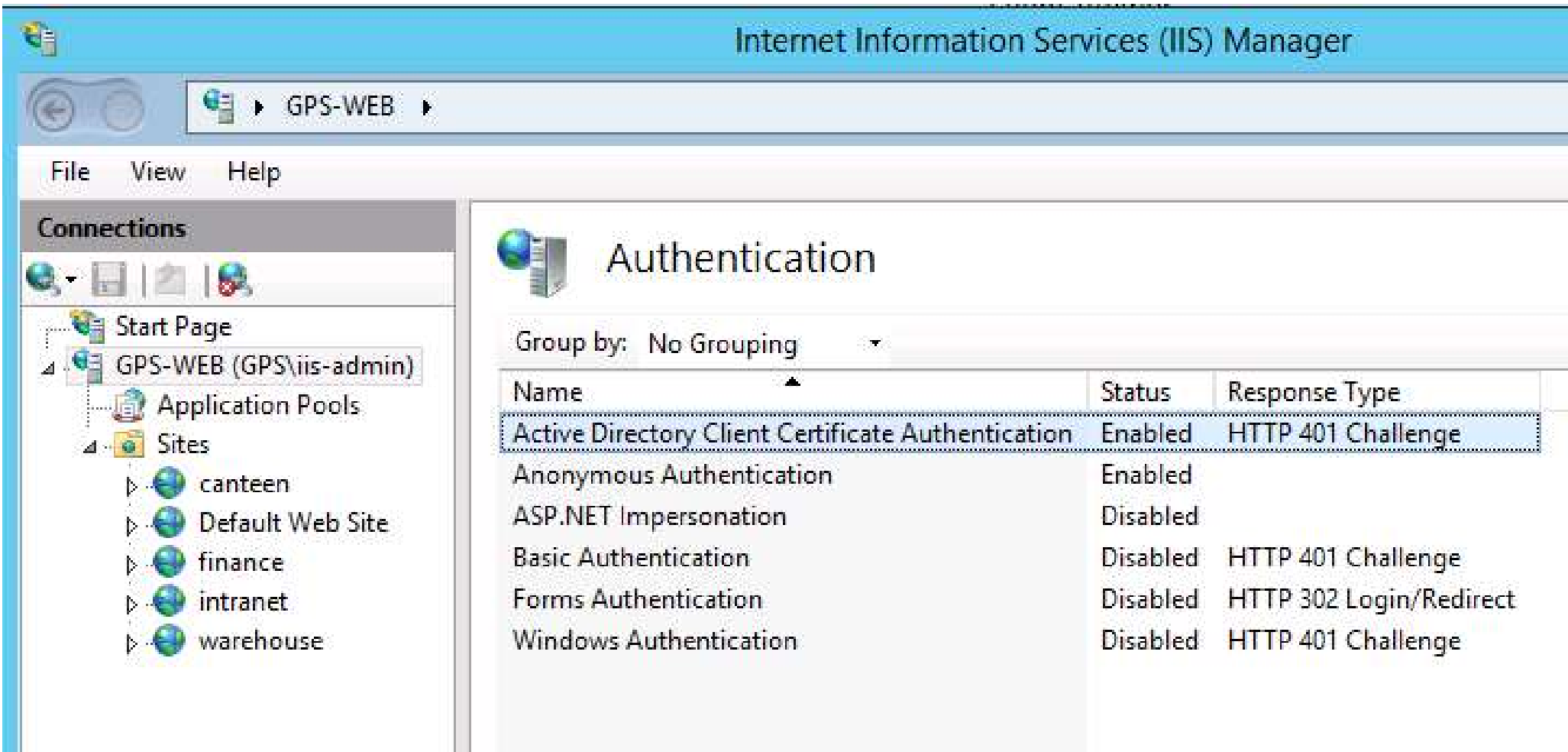
The screenshot shows the Internet Information Services (IIS) Manager interface. The breadcrumb path is GPS-WEB > Sites > finance. The left-hand 'Connections' pane shows the tree structure: Start Page, GPS-WEB (GPS\iis-admin), Application Pools, and Sites. Under Sites, there are several sub-sites: canteen, Default Web Site, finance (selected), intranet, and warehouse. The main pane displays the 'Authentication' settings for the selected 'finance' site. A red rounded rectangle highlights the 'Status' column of the authentication methods table.

Name	Status	Response Type
Anonymous Authentication	Disabled	
ASP.NET Impersonation	Disabled	
Basic Authentication	Disabled	HTTP 401 Challenge
Forms Authentication	Disabled	HTTP 302 Login/Redirect
Windows Authentication	Disabled	HTTP 401 Challenge

IIS TLS client certificate authentication #3

Install Active Directory Client Certificate Authentication

Enable AD mapper server-wide

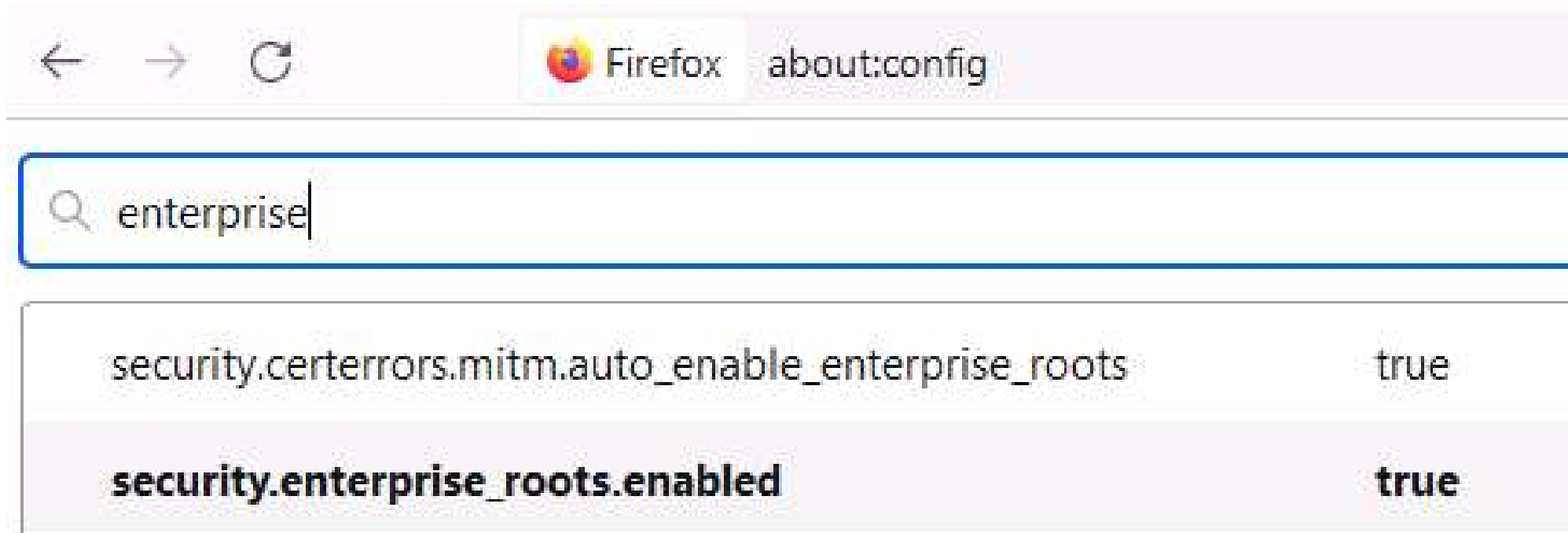


The screenshot shows the Internet Information Services (IIS) Manager interface. The left-hand 'Connections' tree is expanded to show the 'GPS-WEB (GPS\iis-admin)' site. The right-hand pane displays the 'Authentication' settings for this site. A table lists various authentication methods, their status, and their response types. 'Active Directory Client Certificate Authentication' is highlighted, showing it is 'Enabled' with an 'HTTP 401 Challenge' response type. Other methods like 'Anonymous Authentication' are also 'Enabled', while 'Basic Authentication', 'Forms Authentication', and 'Windows Authentication' are 'Disabled'.

Name	Status	Response Type
Active Directory Client Certificate Authentication	Enabled	HTTP 401 Challenge
Anonymous Authentication	Enabled	
ASP.NET Impersonation	Disabled	
Basic Authentication	Disabled	HTTP 401 Challenge
Forms Authentication	Disabled	HTTP 302 Login/Redirect
Windows Authentication	Disabled	HTTP 401 Challenge

Firefox does not see Windows certificates by default

- about:config
 - security.enterprise_roots_enabled



SChannel authentication events on DCs



SChannel logon events on resource servers

Event Properties - Event 4624, Microsoft Windows security auditing.

General Details

Logon Information:

Logon Type: 3

Restricted Admin Mode: -

Impersonation Level: Impersonation

New Logon:

Security ID: GPS\kamil

Account Name: kamil

Account Domain: GPS

Process Information:

Process ID: 0x354

Process Name: C:\Windows\System32\lsass.exe

Network Information:

Workstation Name: GPS-WEB

Source Network Address: -

Source Port: -

Detailed Authentication Information:

Logon Process: Schannel

Authentication Package: Kerberos

Transited Services: -

Package Name (NTLM only): -

Key Length: 0

Log Name: Security

Source: Microsoft Windows security

Event ID: 4624

Level: Information

User: N/A

Logged: 26.09.2024 16:36:06

Task Category: Logon

Keywords: Audit Success

Computer: GPS-WEB.gopas.virtual

Hardware requirements

- Smart card + reader
- Smart card in a reader = token
- USB, PCMCIA
- TPM on motherboard
- Smart card is not a USB flash drive
 - crypto CPU separate from OS
 - performs crypto-operations under PIN protection
 - crypto-memory cannot be "just read"

Hardware drivers

- "bus" drivers for reader
- crypto-provider for the chip
 - Cryptographic Services Provider (CSP)
 - mini-driver DLL for Base Smart Card CSP or Smart Card KSP
- certutil -csplist
- certutil -scinfo

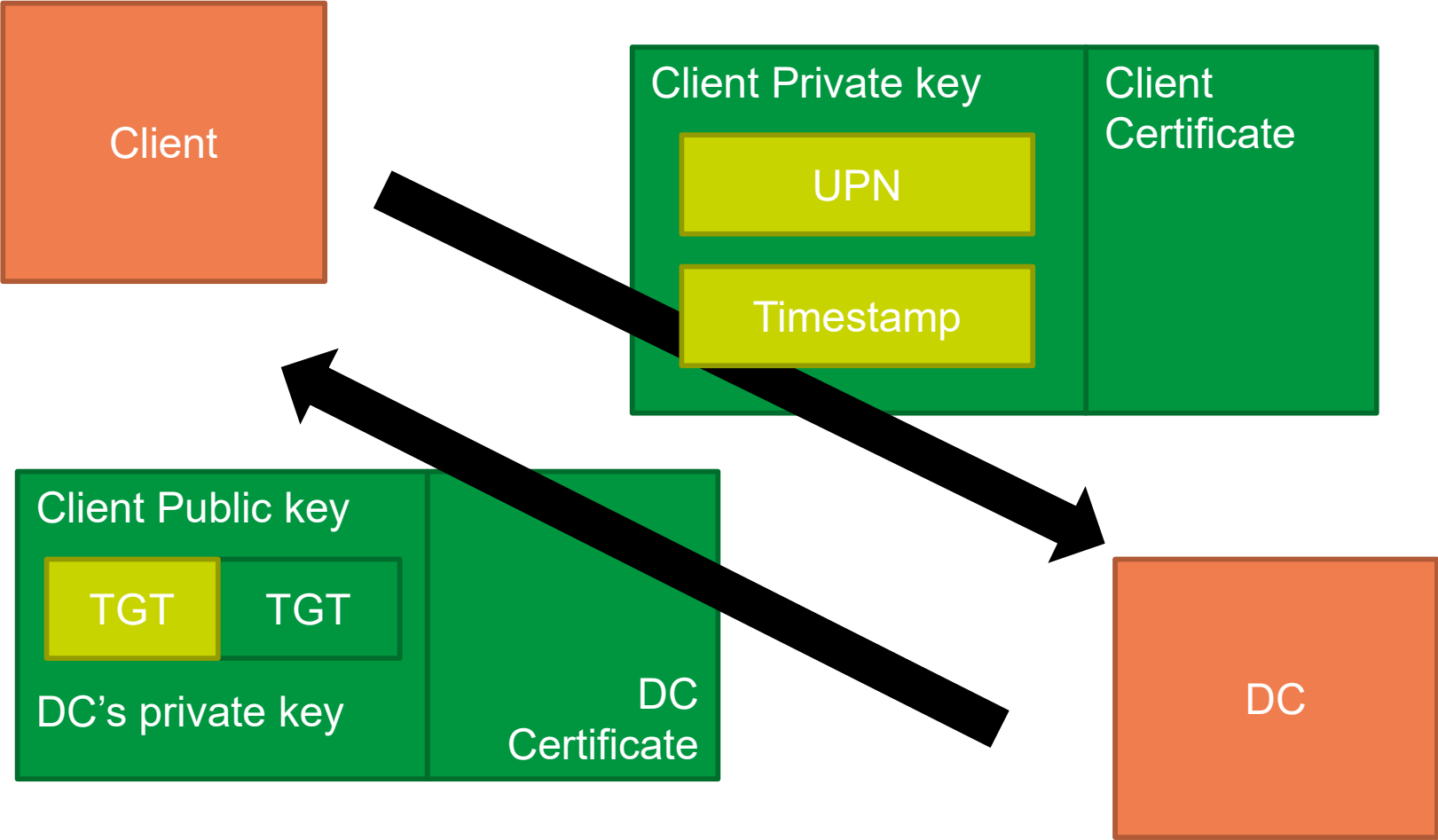
TPM virtual smart-card



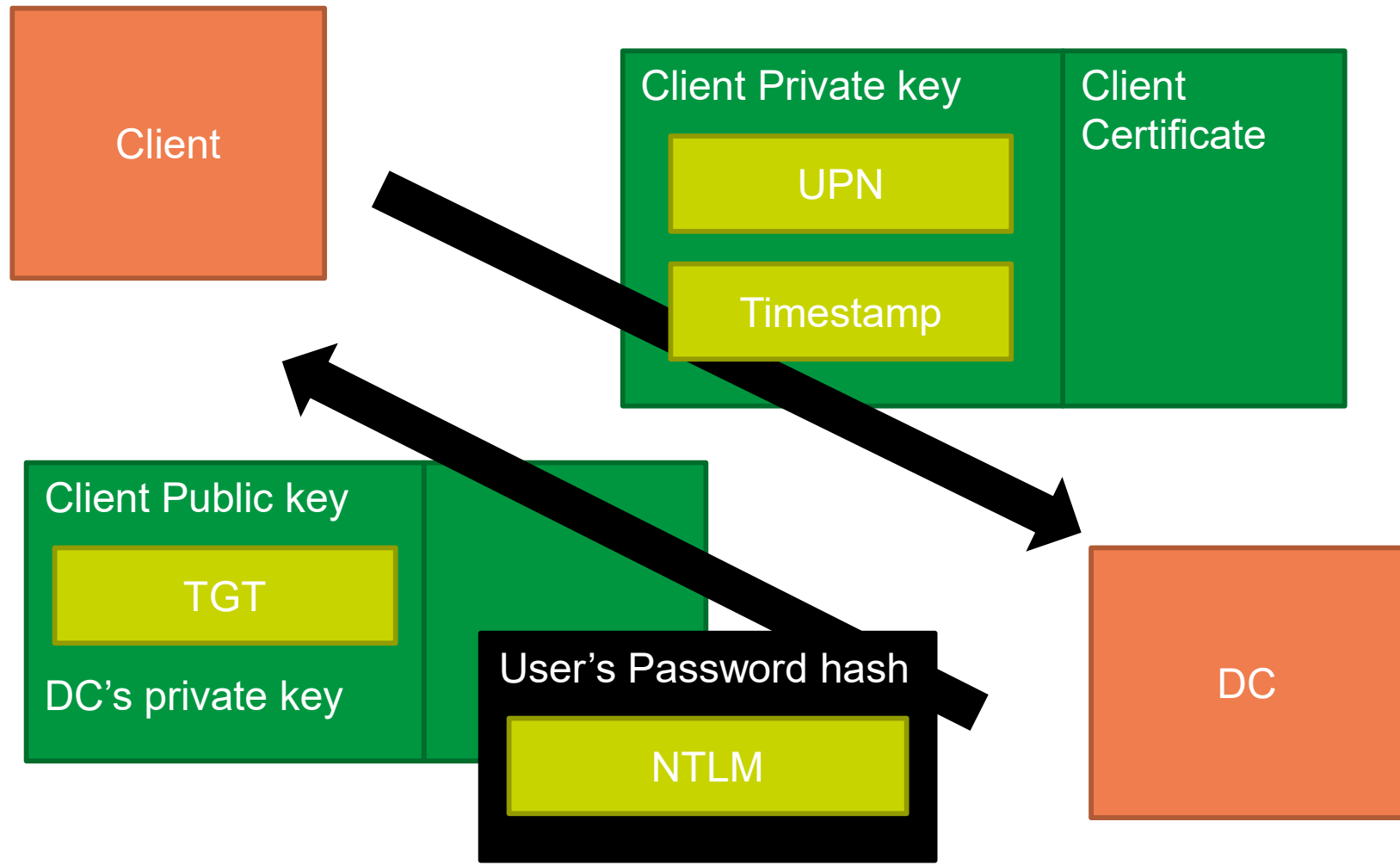
Administrator: Windows PowerShell

```
PS C:\>
PS C:\> tpmvscmgr.exe create /name "userADlogon" /AdminKey PROMPT /PIN Prompt /generate
Enter Admin Key:
*****
Confirm Admin Key:
*****
Enter PIN:
*****
Confirm PIN:
*****
Creating TPM Smart Card...
Initializing the Virtual Smart Card component...
Creating the Virtual Smart Card component...
Initializing the Virtual Smart Card Simulator...
Creating the Virtual Smart Card Simulator...
Initializing the Virtual Smart Card Reader...
Creating the Virtual Smart Card Reader...
Waiting for TPM Smart Card Device...
Authenticating to the TPM Smart Card...
Generating filesystem on the TPM Smart Card...
TPM Smart Card created.
Smart Card Reader Device Instance ID = ROOT\SMARTCARDREADER\0000
PS C:\>
PS C:\> █
```

Smart card logon (PKINIT)



NTLM credentials in PAC



Auditing

 Event Properties - Event 4768, Microsoft Windows security auditing.

General Details

A Kerberos authentication ticket (TGT) was requested.

Account Information:

Account Name:	kamil
Supplied Realm Name:	GOPAS.VIRTUAL
User ID:	GPS\kamil

Service Information:

Service Name:	krbtgt
Service ID:	GPS\krbtgt

Network Information:

Client Address:	::ffff:10.10.0.101
Client Port:	49859

Additional Information:

Ticket Options:	0x40810010
Result Code:	0x0
Ticket Encryption Type:	0x17
Pre-Authentication Type:	15

Certificate Information:

Certificate Issuer Name:	GOPAS Root Online CA
Certificate Serial Number:	6C0000001AB63C60E314ADD34500000000001A
Certificate Thumbprint:	BF4F68501F1D6AB0B40E6110FFBDD122369F21B5

Require S/C for interactive logon

- **Interactive** logon only
 - pre-authentication generate TGT
- Per user account in AD
 - userAccountControl = 262144 (0x40000)
 - GUI randomizes password
- Per computer by GPO
 - all users on the computer

Expired passwords prevent S/C logon as well

2016+ msDS-ExpirePasswordsOnSmartCardOnlyAccounts

book-vendors.com Properties

General Managed By Object Security Attribute Editor

Attributes:

Attribute	Value
msDS-CloudAnchor	<not set>
mS-DS-ConsistencyGuid	<not set>
mS-DS-ConsistencyChildCount	<not set>
msDS-EnabledFeature	<not set>
msDS-ExpirePasswordsOnSmartCardOnlyAccounts	FALSE
msDS-LastKnownRDN	<not set>
msDS-LogonTimeSyncInterval	<not set>
ms-DS-MachineAccountQuota	10

S/C removal behavior

- Log-off
- Lock-out and/or RDP disconnect
- Smart Card Removal Policy service must be enabled
 - GPO